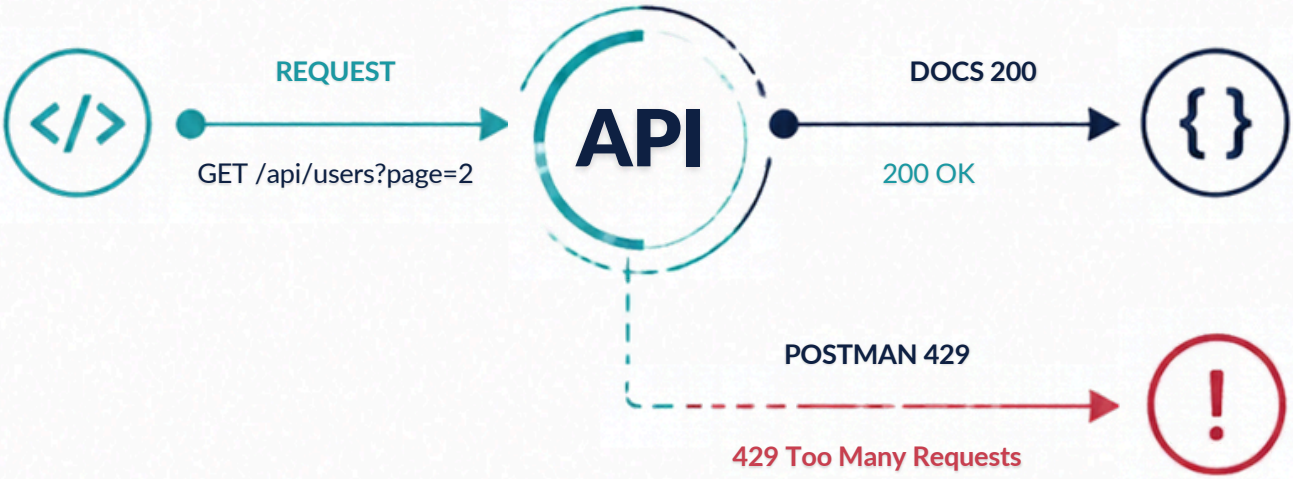
API Security Risk Analysis

Read-only assessment of the ReqRes demo API

Future Interns Cyber Security Task 3 (2026)

Read-only / educational demo



ASSESSMENT DATE
11 November 2026

SCOPE
Read-only assessment of the ReqRes demo API

METHODOLOGY
Manual exploratory review and analysis

Executive summary & scope

EXECUTIVE SUMMARY

This limited read-only review covered the public ReqRes demo API documentation, the classic GET /api/users?page=2 route, one Postman request, and its response headers.

Postman returned HTTP 429 because the anonymous daily IP quota was exhausted: X-Ratelimit-Limit 40; X-Ratelimit-Remaining 0. The documentation widget separately showed HTTP 200 with fixed test records.

No confirmed exploitable vulnerability was identified.

SCOPE & FRAMING

This is not a full production penetration test or security audit.

IN SCOPE

- ReqRes documentation
- GET /api/users?page=2
- One Postman response and its headers
- The documented live example

ASSESSMENT FRAMING

Public educational demo	Read-only review	Fixture data	Limited evidence

Observed behavior is interpreted in context and is not treated as a production finding.

03 Method & evidence

Method

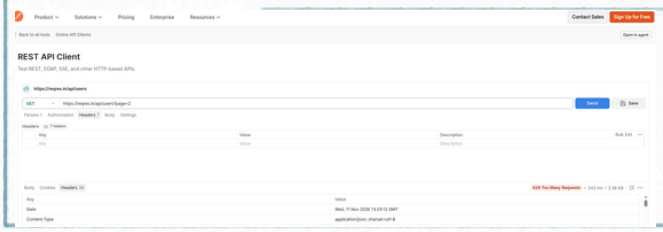
- **Postman Online REST API Client —** one GET request to /api/users?page=2, with response headers inspected in Postman.
- **Browser inspection —** ReqRes official API documentation and its live example.

Browser DevTools were not used; response headers were inspected in Postman.

Scope excluded

- POST, PUT, PATCH and DELETE
- brute force or bypass attempts
- fuzzing
- load or denial-of-service activity
- private systems
- production systems

Evidence 01 | Postman 429



Postman: HTTP 429
Daily demo quota reached.

Evidence 02 | Docs 200



Docs widget: HTTP 200
Fixed sample records.

The 429 Postman response and the documentation's 200 sample are separate observations.

04 Authentication, data & header observations

4.1 AUTHENTICATION AND DATA REVIEW

ReqRes documents the classic /api/users route as unauthenticated and returning fixed demo fixtures. Project collections require x-api-key; per-user routes use a Bearer session token. This review did not test authenticated routes or object-level access.

Expected behavior — informational, not a vulnerability

Public access is consistent with a fixture API intended for demonstration.

VISIBLE SAMPLE FIELDS

ID • email • first name • last name • avatar

The sample fields are fixtures; no live customer data was verified.

4.2 HEADER OBSERVATIONS

Captured Postman 429 response.

HEADER / ELEMENT	OBSERVATION
HTTP status	[redacted] — rate limiting active
X-Ratelimit-Limit	40
X-Ratelimit-Remaining	0
X-Ratelimit-Reset	present
Cache-Control	no-store
Strict-Transport-Security	max-age=31536000; includeSubDomains
X-Content-Type-Options	nosniff
X-Frame-Options	DENY
Referrer-Policy	strict-origin-when-cross-origin

HTTP 429 and X-Ratelimit-Remaining: 0 show the daily quota was enforced. This is a working control, not a vulnerability.

Access-Control-Allow-Origin: * is expected on this public fixture API and is not a vulnerability by itself.

Server and X-Powered-By identify the service. This is a Low / informational hardening note with minimal demo impact.

X-XSS-Protection: 0 is not treated as a flaw.

No Confirmed High or Medium findings

RISK REGISTER

Low / Informational — unnecessary product or service identification headers

OBSERVATION:	Server and X-Powered-By disclose service branding.
BUSINESS IMPACT:	Minimal in this educational demo context.
DISPOSITION:	Remove unnecessary fingerprinting headers on production APIs where not required.

Control observed

Functioning rate limiting. The captured HTTP 429 response, X-RateLimit-Limit 40 and X-RateLimit-Remaining 0 show that the anonymous quota was enforced.

Expected demo behavior

Unauthenticated access to fixed fixture data is consistent with the public ReqRes demonstration route and is informational, not a confirmed flaw.

Recommendations for a real SaaS API

1. Require authentication for private records.
2. Enforce object-level authorization on every record access.
3. Return only the fields a client needs.
4. Rate-limit by account or client where appropriate, and document reset and retry behavior.
5. Restrict cross-origin access where sensitive data or credentials require it.
6. Validate inputs at the boundary.
7. Log security-relevant events for detection and review.

Recommendations are forward-looking controls, not findings confirmed on ReqRes.

LIMITATIONS, CONCLUSION & REFERENCES

LIMITATIONS

- The target is an educational demo with fixed fixtures, not a production system.
- Only one Postman request was made and it reached the documented daily quota; the captured headers therefore come from a 429 response.
- The official docs showed a separate 200 live sample.
- No tokens, real users or write operations were tested.
- Input validation, broken object-level authorization (BOLA), and abuse behavior were not tested.

Useful controls were observed, and this limited review establishes no confirmed exploitable issue.

The evidence supports a cautious informational assessment, not a production security conclusion.

REFERENCES

- ReqRes API docs — https://reqres.in/docs
- ReqRes free API — https://reqres.in/free-json-api
- OWASP API Security — https://github.com/OWASP/API-Security
- Shieldfy API Security Checklist — https://github.com/shieldfy/API-Security-Checklist
- Public APIs list — https://github.com/public-apis/public-apis
- Postman REST API Client — https://www.postman.com/tools/rest-api-client

The three GitHub repositories are study references only. Analysis wording in this report is original and does not reproduce repository text.